



ZAP by
Checkmarx

segundo escaneo de mi aplicacion en frontend s9

Sitio: <http://localhost:8081>

Generado a vie, 8 may 2026 18:20:50

ZAP Versión: 2.17.0

ZAP by [Checkmarx](#)

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	3
Bajo	3
Informativo	3

Insights

Level	Razón	Site	Descripción	Statistic
Información	Informativo		Percentage of network failures	1 %
Información	Informativo	http://localhost:8081	Percentage of responses with status code 2xx	68 %
Información	Informativo	http://localhost:8081	Percentage of responses with status code 3xx	1 %
Información	Exceeded Low	http://localhost:8081	Percentage of responses with status code 4xx	27 %
Información	Informativo	http://localhost:8081	Percentage of responses with status code 5xx	2 %
Información	Informativo	http://localhost:8081	Percentage of endpoints with content type application /json	18 %

Información	Informativo	http://localhost:8081	Percentage of endpoints with content type text/css	2 %
Información	Informativo	http://localhost:8081	Percentage of endpoints with content type text/html	76 %
Información	Informativo	http://localhost:8081	Percentage of endpoints with method GET	92 %
Información	Informativo	http://localhost:8081	Percentage of endpoints with method POST	7 %
Información	Informativo	http://localhost:8081	Count of total endpoints	38
Información	Informativo	http://localhost:8081	Percentage of slow responses	1 %

Alertas

Nombre	Nivel de riesgo	Número de Instancias
CSP: Directiva Wildcard	Medio	Systemic
CSP: Failure to Define Directive with No Fallback	Medio	Systemic
Cabecera Content Security Policy (CSP) no configurada	Medio	Systemic
CSP: Avisos	Bajo	Systemic
Cookie sin el atributo SameSite	Bajo	2
Divulgación de Marcas de Tiempo - Unix	Bajo	Systemic
Atributo de elemento HTML controlable por el usuario (XSS potencial)	Informativo	24
Petición de Autenticación Identificada	Informativo	1
Respuesta de Gestión de Sesión Identificada	Informativo	10

Detalles de la Alerta

Medio	CSP: Directiva Wildcard
Descripción	Content Security Policy (CSP) es una capa de seguridad añadida que ayuda a detectar y mitigar ciertos tipos de ataques. Incluyendo (pero no limitado a) Cross Site Scripting (XSS), y ataques de inyección de datos. Estos ataques se utilizan, para todo, desde el robo de datos a la desfiguración de sitios o la distribución de malware. CSP proporciona un conjunto de cabeceras HTTP estándar que permiten a los propietarios de sitios web declarar las fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página. Los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustables como applets Java, ActiveX y archivos de audio y vídeo.

URL	http://localhost:8081
Nombre del Nodo	http://localhost:8081
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Las siguientes directivas permiten fuentes comodín (o ancestros), no están definidas, o están definidas de forma demasiado amplia: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src
URL	http://localhost:8081/mascotas/13
Nombre del Nodo	http://localhost:8081/mascotas/13
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Las siguientes directivas permiten fuentes comodín (o ancestros), no están definidas, o están definidas de forma demasiado amplia: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src
URL	http://localhost:8081/mascotas/2
Nombre del Nodo	http://localhost:8081/mascotas/2
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Las siguientes directivas permiten fuentes comodín (o ancestros), no están definidas, o están definidas de forma demasiado amplia: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src
URL	http://localhost:8081/mascotas/4
Nombre del Nodo	http://localhost:8081/mascotas/4
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Las siguientes directivas permiten fuentes comodín (o ancestros), no están definidas, o están definidas de forma demasiado amplia: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src
URL	http://localhost:8081/mascotas/5
Nombre del Nodo	http://localhost:8081/mascotas/5

Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Las siguientes directivas permiten fuentes comodín (o ancestros), no están definidas, o están definidas de forma demasiado amplia: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src
Instancia	Systemic
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está configurado apropiadamente para establecer la cabecera de Política de Seguridad de Contenido.
Referencia	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medio	CSP: Failure to Define Directive with No Fallback
Descripción	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://localhost:8081
Nombre del Nodo	http://localhost:8081
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:8081/mascotas/13
Nombre del Nodo	http://localhost:8081/mascotas/13
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:8081/mascotas/2
Nombre del Nodo	http://localhost:8081/mascotas/2
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'

Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:8081/mascotas/4
Nombre del Nodo	http://localhost:8081/mascotas/4
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:8081/mascotas/5
Nombre del Nodo	http://localhost:8081/mascotas/5
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: connect-src 'self' frame-ancestors 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instancia	Systemic
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está configurado apropiadamente para establecer la cabecera de Política de Seguridad de Contenido.
Referencia	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055
Medio	Cabecera Content Security Policy (CSP) no configurada
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.
URL	http://localhost:8081/adopciones/seguimiento
Nombre del Nodo	http://localhost:8081/adopciones/seguimiento
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:8081/mascotas/13

Nombre del Nodo	http://localhost:8081/mascotas/13
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:8081/mascotas/15
Nombre del Nodo	http://localhost:8081/mascotas/15
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:8081/mascotas/16
Nombre del Nodo	http://localhost:8081/mascotas/16
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:8081/mascotas/4
Nombre del Nodo	http://localhost:8081/mascotas/4
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	Systemic
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Bajo	CSP: Avisos
	Content Security Policy (CSP) es una capa de seguridad añadida que ayuda a detectar y mitigar (pero no limitado a) Cross Site Scripting (XSS), y ataques de inyección de datos.

Descripción	para todo, desde el robo de datos a la desfiguración de sitios o la distribución de malware. C: de cabeceras HTTP estándar que permiten a los propietarios de sitios web declarar las fuentes que los navegadores deberían poder cargar en esa página. Los tipos cubiertos son JavaScript, fuentes, imágenes y objetos incrustables como applets Java, ActiveX y archivos de audio y v
URL	http://localhost:8081
Nombre del Nodo	http://localhost:8081
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: conr 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Errores: 'none' must not be combined with any other source-expression Advertencias: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate scheme data: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self'
URL	http://localhost:8081/?edadMax=0&edadMin=0&especie=ZAP&estadoAdopcion=DISPONIBLE&genero=MASCULIN
Nombre del Nodo	http://localhost:8081/ (edadMax,edadMin,especie,estadoAdopcion,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: conr 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Errores: 'none' must not be combined with any other source-expression Advertencias: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate scheme data: Duplicate source-expression 'self'

	Duplicate source-expression 'self'
	Duplicate source-expression 'self'
	Duplicate source-expression 'self'
URL	http://localhost:8081/mascotas/14
Nombre del Nodo	http://localhost:8081/mascotas/14
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: conr 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Errores: 'none' must not be combined with any other source-expression Advertencias: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate scheme data: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self'
URL	http://localhost:8081/mascotas/15
Nombre del Nodo	http://localhost:8081/mascotas/15
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: conr 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Errores: 'none' must not be combined with any other source-expression Advertencias: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate scheme data: Duplicate source-expression 'self'

	Duplicate source-expression 'self'
	Duplicate source-expression 'self'
	Duplicate source-expression 'self'
URL	http://localhost:8081/mascotas/18
Nombre del Nodo	http://localhost:8081/mascotas/18
Método	GET
Ataque	
Evidencia	default-src 'self' script-src 'self' style-src 'self' img-src 'self' data: https: font-src 'self' data: con 'self' base-uri 'self' form-action 'self' object-src 'none'
Otra información	Errores: 'none' must not be combined with any other source-expression Advertencias: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate scheme data: Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self' Duplicate source-expression 'self'
Instancia	Systemic
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está c para establecer la cabecera de Política de Seguridad de Contenido.
Referencia	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Bajo	Cookie sin el atributo SameSite
Descripción	Se ha establecido una cookie sin el atributo SameSite, lo que significa que la cookie puede ser enviada como resultado de una solicitud 'cross-site'. El atributo SameSite es una medida eficaz para contrarrestar la falsificación de peticiones entre sitios, la inclusión de scripts entre sitios y los ataques de sincronización.
URL	http://localhost:8081/robots.txt
Nombre del Nodo	http://localhost:8081/robots.txt
Método	GET
Ataque	

Evidencia	Set-Cookie: JSESSIONID
Otra información	
URL	http://localhost:8081/sitemap.xml
Nombre del Nodo	http://localhost:8081/sitemap.xml
Método	GET
Ataque	
Evidencia	Set-Cookie: JSESSIONID
Otra información	
Instancia	2
Solución	Asegúrese que el atributo SameSite está establecido como 'lax' o idealmente 'strict' para todas las cookies.
Referencia	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Bajo	Divulgación de Marcas de Tiempo - Unix
Descripción	Una marca de tiempo fue revelada por la aplicación/servidor web. - Unix
URL	http://localhost:8081
Nombre del Nodo	http://localhost:8081
Método	GET
Ataque	
Evidencia	1533738363
Otra información	1533738363, que se evalúa como: 2018-08-08 10:26:03.
URL	http://localhost:8081
Nombre del Nodo	http://localhost:8081
Método	GET
Ataque	
Evidencia	1552728089
Otra información	1552728089, que se evalúa como: 2019-03-16 06:21:29.
URL	http://localhost:8081/
Nombre del Nodo	http://localhost:8081/
Método	GET
Ataque	
Evidencia	1533738363
Otra información	1533738363, que se evalúa como: 2018-08-08 10:26:03.
URL	http://localhost:8081/

Nombre del Nodo	http://localhost:8081/
Método	GET
Ataque	
Evidencia	1552728089
Otra información	1552728089, que se evalúa como: 2019-03-16 06:21:29.
URL	http://localhost:8081/mascotas/11
Nombre del Nodo	http://localhost:8081/mascotas/11
Método	GET
Ataque	
Evidencia	1533738363
Otra información	1533738363, que se evalúa como: 2018-08-08 10:26:03.
Instancia	Systemic
Solución	Confirmar que los datos encontrados de información sobre la marca de tiempo no son sensibles, ni se pueden usar en patrones explotables de divulgación.
Referencia	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Informativo	Atributo de elemento HTML controlable por el usuario (XSS potencial)
Descripción	Esta comprobación examina la entrada proporcionada por el usuario en parámetros de cader para identificar dónde podrían estar controlados ciertos valores de atributos HTML. Esto prop calientes para XSS (cross-site scripting) que requerirán una revisión adicional por parte de u determinar la explotabilidad.
URL	http://localhost:8081/?edadMax=0&edadMin=0&especie=ZAP&estadoAdopcion=DISPONIBLE&genero=MASCULIN
Nombre del Nodo	http://localhost:8081/ (edadMax,edadMin,especie,estadoAdopcion,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar ca es posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:especie=ZAP El valor controlado por el usuario
URL	http://localhost:8081/?edadMax=0&edadMin=0&especie=ZAP&estadoAdopcion=DISPONIBLE&genero=MASCULIN
Nombre del Nodo	http://localhost:8081/ (edadMax,edadMin,especie,estadoAdopcion,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar ca es posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:estadoAdopcion=DISPONIBLE El valor controla disponible.

URL	http://localhost:8081/?edadMax=0&edadMin=0&especie=ZAP&estadoAdopcion=DISPONIBLE&genero=MASCULINO
Nombre del Nodo	http://localhost:8081/ (edadMax,edadMin,especie,estadoAdopcion,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:genero=MASCULINO El valor controlado por el usuario era:
URL	http://localhost:8081/?edadMax=0&edadMin=0&especie=ZAP&estadoAdopcion=DISPONIBLE&genero=MASCULINO
Nombre del Nodo	http://localhost:8081/ (edadMax,edadMin,especie,estadoAdopcion,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:raza=ZAP El valor controlado por el usuario era:
URL	http://localhost:8081/?edadMax=0&edadMin=0&especie=ZAP&estadoAdopcion=DISPONIBLE&genero=MASCULINO
Nombre del Nodo	http://localhost:8081/ (edadMax,edadMin,especie,estadoAdopcion,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:ubicacion=ZAP El valor controlado por el usuario era:
URL	http://localhost:8081/adopciones/disponibles?edadMax=0&edadMin=0&especie=ZAP&genero=MASCULINO&raza=ZAP&ubicacion=ZAP
Nombre del Nodo	http://localhost:8081/adopciones/disponibles (edadMax,edadMin,especie,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:especie=ZAP El valor controlado por el usuario era:
URL	http://localhost:8081/adopciones/disponibles?edadMax=0&edadMin=0&especie=ZAP&genero=MASCULINO&raza=ZAP&ubicacion=ZAP
Nombre del Nodo	http://localhost:8081/adopciones/disponibles (edadMax,edadMin,especie,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:genero=MASCULINO El valor controlado por el usuario era:

URL	http://localhost:8081/adopciones/disponibles?edadMax=0&edadMin=0&especie=ZAP&genero=MASCULINO&raza=ZAP&ubicacion=ZAP
Nombre del Nodo	http://localhost:8081/adopciones/disponibles (edadMax,edadMin,especie,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres como es posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una etiqueta [value] La entrada de usuario encontrada era:raza=ZAP El valor controlado por el usuario era:raza=ZAP
URL	http://localhost:8081/adopciones/disponibles?edadMax=0&edadMin=0&especie=ZAP&genero=MASCULINO&raza=ZAP&ubicacion=ZAP
Nombre del Nodo	http://localhost:8081/adopciones/disponibles (edadMax,edadMin,especie,genero,raza,ubicacion)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres como es posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una etiqueta [value] La entrada de usuario encontrada era:ubicacion=ZAP El valor controlado por el usuario era:ubicacion=ZAP
URL	http://localhost:8081/adopciones/seguimiento?codigo=ZAP
Nombre del Nodo	http://localhost:8081/adopciones/seguimiento (codigo)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres como es posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una etiqueta [value] La entrada de usuario encontrada era:codigo=ZAP El valor controlado por el usuario era:codigo=ZAP
URL	http://localhost:8081/adopciones/solicitar?animalId=10
Nombre del Nodo	http://localhost:8081/adopciones/solicitar (animalId)
Método	GET
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres como es posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una etiqueta [value] La entrada de usuario encontrada era:animalId=10 El valor controlado por el usuario era:animalId=10
URL	http://localhost:8081/adopciones/seguimiento/mensaje
Nombre del Nodo	http://localhost:8081/adopciones/seguimiento/mensaje ()(_csrf,codigoSeguimiento,cuerpo)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres como es posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una etiqueta [value] La entrada de usuario encontrada era:codigoSeguimiento=ZAP El valor controlado por el usuario era:codigoSeguimiento=ZAP
URL	http://localhost:8081/adopciones/solicitar

Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier cosa posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era: _tieneNinos=on El valor controlado por el usuario es
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier cosa posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era: _tieneOtrasMascotas=on El valor controlado por el usuario es
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier cosa posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [content] La entrada de usuario encontrada era: animalId=1 El valor controlado por el usuario es scale=1.
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier cosa posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era: ciudad=ZAP El valor controlado por el usuario es
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier cosa posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era: direccion=ZAP El valor controlado por el usuario es

URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:email=zaproxy@example.com El valor controlado por el usuario era:email=zaproxy@example.com.
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:nombreCompleto=ZAP El valor controlado por el usuario era:nombreCompleto=ZAP
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [content] La entrada de usuario encontrada era:personasEnHogar=1 El valor controlado por el usuario era:personasEnHogar=1 width, initial-scale=1.
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar caracteres posibles XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:telefono=ZAP El valor controlado por el usuario era:telefono=ZAP
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	

Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier valor posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:tieneNinos=true El valor controlado por el usuario
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier valor posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:tieneOtrasMascotas=true El valor controlado por el usuario
URL	http://localhost:8081/adopciones/solicitar
Nombre del Nodo	http://localhost:8081/adopciones/solicitar ()(_csrf,_tieneNinos,_tieneOtrasMascotas,animalId,experienciaMascotas,motivacionAdopcion,nombreCompleto,personasEnHogar,telefono,tiene tipoVivienda)
Método	POST
Ataque	
Evidencia	
Otra información	Se han encontrado valores de atributos HTML controlados por el usuario. Intente inyectar cualquier valor posible XSS. La página en la siguiente URL parece incluir una entrada de usuario en una [value] La entrada de usuario encontrada era:tipoVivienda=CASA El valor controlado por el usuario
Instancia	24
Solución	Válida la entrada y sanea la salida antes de escribirla en cualquier atributo HTML.
Referencia	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031

Informativo	Petición de Autenticación Identificada
Descripción	La petición en cuestión se ha identificado como una petición de autenticación. El campo "Otra información" contiene un conjunto de líneas key=value que identifican cualquier campo relevante. Si la solicitud está en un contexto que tiene un método de autenticación configurado como "Detección automática", esta regla cambiará la autenticación para que coincida con la petición identificada.
URL	http://localhost:8081/login
Nombre del Nodo	http://localhost:8081/login ()(_csrf,password,username)
Método	POST
Ataque	
Evidencia	password
Otra información	userParam=username userValue=ZAP passwordParam=password referer=http://localhost:8081/login csrfToken=_csrf
Instancia	1

Solución	Se trata de una alerta informativa y no de una vulnerabilidad, por lo que no hay nada que corregir.
Referencia	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informativo	Respuesta de Gestión de Sesión Identificada
Descripción	Se ha identificado que la respuesta dada contiene un token de gestión de sesión. El campo 'Other Info' contiene un conjunto de tokens de cabecera que pueden utilizarse en el método Header Based Session Management (gestión de sesión basado en cabecera). Si la petición se encuentra en un contexto que tiene un método Session Management establecido en "Auto-Detect", esta regla cambiará la gestión de sesión para utilizar los tokens identificados.
URL	http://localhost:8081/adopciones
Nombre del Nodo	http://localhost:8081/adopciones
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/adopciones/seguimiento
Nombre del Nodo	http://localhost:8081/adopciones/seguimiento
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/adopciones/seguimiento?codigo=ZAP
Nombre del Nodo	http://localhost:8081/adopciones/seguimiento (codigo)
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/adopciones/seguimiento/mensaje
Nombre del Nodo	http://localhost:8081/adopciones/seguimiento/mensaje
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/adopciones/solicitar?animalId=13

Nombre del Nodo	http://localhost:8081/adopciones/solicitar (animalId)
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/login
Nombre del Nodo	http://localhost:8081/login
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/login?error
Nombre del Nodo	http://localhost:8081/login (error)
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/robots.txt
Nombre del Nodo	http://localhost:8081/robots.txt
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/sitemap.xml
Nombre del Nodo	http://localhost:8081/sitemap.xml
Método	GET
Ataque	
Evidencia	JSESSIONID
Otra información	cookie:JSESSIONID
URL	http://localhost:8081/robots.txt
Nombre del Nodo	http://localhost:8081/robots.txt
Método	GET
Ataque	
Evidencia	JSESSIONID

Otra información	cookie:JSESSIONID
Instancia	10
Solución	Se trata de una alerta informativa y no de una vulnerabilidad, por lo que no hay nada que corregir.
Referencia	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112